Lecture plan · for the lecturer

Security principles and threat modelling

Cyber security · University · Lecture 1

Time
60 min

Materials
Projector or board; The lecture slides and the seminar sheet from the kit; Phones or laptops with Darsi, for the lab

Learning goals

- Apply classic design principles.
- Threat-model with STRIDE.
- Teach principles through a real system.

Activity: Model the portal

1. Warm-up (5 min): Show the open-bucket headline and ask teams to name the failure in one word.
2. Teach (10 min): Present the eight principles, each with one breach that broke it.
3. Draw (15 min): Teams draw the portal's data flow and mark trust boundaries.
4. Threats (25 min): Find one threat per letter, rate it, and propose a mitigation.
5. Wrap-up (5 min): Students write the muddiest point of the lecture and one question; read them before next week.

Discussion

- Which threat surprised you?
- Which principle covers most threats?
- How will you grade the threat table?

Exit ticket

- Name one trust boundary in a system you use and one STRIDE threat at it.

Try it in your next lecture
Give teams a one-page data-flow diagram of course registration; each finds one threat per STRIDE letter and proposes a fix.

Seminar sheet · for students

Security principles and threat modelling

Cyber security · University · Lecture 1

Name _____ Group _____ Date _____

1 **A student edits a hidden form field to change their grade before saving. Which STRIDE threat?**

◯ Tampering ◯ Repudiation ◯ Spoofing

2 **Map threats to properties.**

Spoofing violates _____, and denial of service violates _____.

Word bank: integrity · availability · authentication · logging

3 **Which design decisions follow least privilege? Choose all that apply.**

☐ The grading service can read submissions but not change marks

☐ One admin account shared by all staff ☐ The web server's database user cannot drop tables

☐ Teaching assistants see only their own sections

4 **Open design means a system's security should not depend on keeping its design secret.**

◯ True ◯ False

5 **Match each threat to its usual mitigation.**

Spoofing	• • • •	Server-side validation and integrity checks
Tampering	• • • •	Strong authentication
Repudiation	• • • •	Least privilege and authorisation checks
Elevation of privilege	• • • •	Tamper-evident audit logs

Answers · for the lecturer

Security principles and threat modelling

Cyber security · University · Lecture 1

1 **Tampering**

Modifying data without authorisation is tampering; validate on the server.

2 **Spoofing violates authentication, and denial of service violates availability.**

Each STRIDE letter targets one property: S → authentication, D → availability.

3 **The grading service can read submissions but not change marks; Teaching assistants see only their own sections; The web server's database user cannot drop tables**

A shared admin account grants everyone maximum rights and destroys accountability.

4 **True**

Security should rest on keys, not secrecy of mechanism, echoing Kerckhoffs's principle.

5 **Spoofing — Strong authentication**
Tampering — Server-side validation and integrity checks
Repudiation — Tamper-evident audit logs
Elevation of privilege — Least privilege and authorisation checks

A threat table with a mitigation per row is a gradeable artefact.

For you to think about

Which system that your students use daily could you threat-model in class? What is its most interesting trust boundary?